

Actividad 08

Traversal sequences blocked with absolute path bypass

Bypass de filtro — ruta absoluta

Nombre: Tristán Rivera Magdalena Yesenia

Matrícula: 174702

Materia / Grupo: CNO IV — Programación WAP · T37A

Profesor: Servando López Contreras

Herramienta: Burp Suite Community Edition

URL: <https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>

OBJETIVO

Evadir un filtro que bloquea secuencias relativas (../) pero no valida si la ruta recibida es absoluta.

EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

El servidor detecta y elimina cualquier ../ en el input, pero no verifica si el `filename` ya viene como una ruta absoluta (empezando en /). Como los sistemas de archivos Unix resuelven rutas absolutas desde la raíz sin importar el directorio base configurado, basta con mandar la ruta completa del archivo objetivo.

PROCEDIMIENTO PASO A PASO

1. Activar Intercept on en Burp y hacer clic en un producto.
2. Interceptar `GET /image?filename=N.jpg` y mandarla a Repeater.
3. Sustituir el valor de `filename` por una ruta absoluta directa, sin usar ../.
4. Enviar y confirmar que el filtro de secuencias relativas no la detecta como maliciosa.
5. Revisar el Response y el badge "Lab solved".

PAYLOAD UTILIZADO

```
GET /image?filename=/etc/passwd HTTP/2
```

Al no contener ../, el filtro de secuencias relativas la deja pasar sin modificarla; el sistema de archivos interpreta la ruta absoluta y entrega `/etc/passwd` directamente, ignorando el directorio base configurado por la aplicación.

MITIGACIÓN RECOMENDADA

Rechazar cualquier input que comience con / o una letra de unidad (Windows), además de filtrar secuencias relativas. Mejor aún: resolver la ruta canónica final y confirmar que sigue dentro del directorio base permitido.

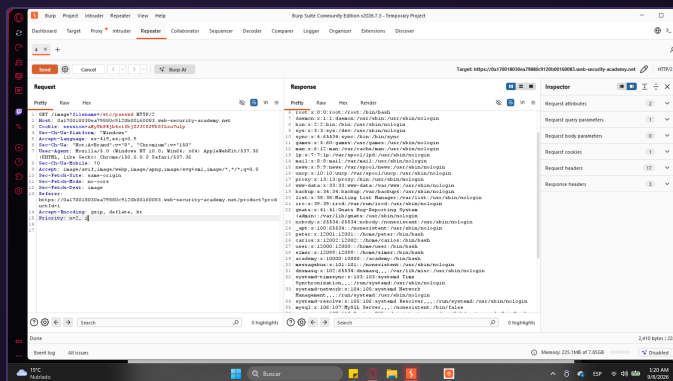


Figura 1. Request en Burp Repeater con el payload + Response con /etc/passwd



Figura 2. Confirmación "Lab solved" en PortSwigger Web Security Academy